

CISM Domain 3B — InfoSec Program Management: Exam Essentials

Second half of Domain 3 (33% of the exam). Covers control design/selection (3B1), implementation/integration (3B2), testing/evaluation (3B3), awareness & training (3B4), external services (3B5), and communication/reporting (3B6).

Control Design & Selection (3B1)

- Balance **people, process, technology**. Select security technologies primarily on their **ability to mitigate business risks** (exam answer) — not cost, novelty, or reviews.
- **Control objective** = clear statement of desired result; must align with business objectives and be cost-effective. Objective = design goal = effectiveness metric.
- Design sequence: identify risks → define acceptable risk level → design controls to reach it.
- Selection criteria beyond cost: productivity impact, **TCO**, user acceptance, legal/regulatory mandates, adaptability, scalability, monitorability, robustness.
- **Physical security is the FOUNDATION** — “there is no security without physical security.”
- **Fail-safe/fail-secure vs fail-open**: security-critical systems (banking) fail CLOSED; safety-critical systems (fire doors) fail OPEN. Prefer **restrictive (deny by default)** and **least privilege**.
- Review controls for: policy compliance, self-protection, alerting, testing, placement/layering (**defense in depth**), bypass paths, single points of failure, unnecessary redundancy.

Foundational Tech: Crypto & PKI (know use cases, not internals)

Concept	Know this
Symmetric (AES)	One shared key; fast — bulk data encryption; poor scalability/key distribution; no non-repudiation
Asymmetric (RSA, DH, ECC)	Public/private key pair; key distribution, digital signatures, non-repudiation; encrypt with recipient’s PUBLIC key, decrypt with their PRIVATE key
Hashing	ONE-WAY, fixed-length output, collision-free — integrity verification
Digital signature	Hash encrypted with SENDER’s PRIVATE key → authentication + non-repudiation + integrity
4 crypto goals	Confidentiality, Integrity, Authentication, Non-repudiation
PKI	Root CA (root of trust — keep OFFLINE) → subordinate/policy CA → issuing CA. CRL = downloaded revocation list; OCSP = faster status query; stapling = server pre-fetches OCSP response; pinning = detect fraudulent certs

Control Implementation & Integration (3B2)

- **Safeguards** = **proactive** (reduce likelihood); **countermeasures** = **reactive** (reduce impact after).
- **Categories**: technical/logical (encryption, firewalls, ACLs), physical (guards, fences, cameras), administrative/managerial (policies, training, background checks). One control can serve multiple types depending on context (camera = deterrent + detective).

Control type	Purpose	Exam keywords
Deterrent	Discourage policy violations	warning, sign, visibility, perception
Preventive	Stop unwanted activity from occurring	access control, authentication, firewall, encryption
Detective	Discover unwanted activity	monitoring, audit, logging, alert
Corrective	Return systems to normal after an event	backup, restore, incident response, patching
Compensating	Alternative when primary control is impractical	alternative, backup, redundancy
Directive	Direct/encourage compliance	policy, procedure, standard, guideline

- **Security baselines** = best way to ensure platform settings comply with policy (exam answer). Deviations usually mean **STRICTER** controls for critical assets.
- If issues can't be fixed before launch: **senior management formally reviews and accepts residual risk** — documented.
- **Segregation of Duties** (developer ≠ deployer); where impractical, use **compensating controls**: extra monitoring, mandatory vacations, job rotation.
- **Liaisons** bridge security and departments: IT audit, IT ops, business managers, HR (background checks, AUP), legal, procurement, PMO, QA, compliance/privacy. Employees = first line of defense.
- **Integrate security into IT processes** (shift left): SDLC from planning phase, DevSecOps (security automated into CI/CD), change management (security is a checkpoint), configuration management (**misconfigurations are a leading breach cause** — automate), release management (test before production).
- **Zero trust**: assume breach, verify explicitly, least privilege — replaces perimeter “trust but verify.” Cloud: know deployment models (private/public/community/hybrid) and shared responsibility (IaaS→SaaS: provider takes on more). VPN: transport mode = client-to-site (split vs full tunnel); tunnel mode = site-to-site. VM risks: escape (patch hypervisor) and sprawl (policy + scanning).

Control Testing & Evaluation (3B3)

- Evaluate via periodic assessments, internal/external audits, continuous monitoring, penetration testing. We **manage risk, never eliminate it**.
- **Inherent strength** (design robustness) ≠ **practical strength** — complex/costly controls invite workarounds. Automated ≠ automatically effective (e.g., forced 30-day password changes breed weak patterns); manual ≠ weak (trained guards on random rounds).
- Preference when feasible: **preventive, automated, formal (documented)**.
- Recommendation flow: risk assessment → prioritize → **cost-benefit analysis** → involve business units. Never kill productivity.
- **ALL control changes go through formal change management** + acceptance testing. Threat/vulnerability assessment in change management **reduces the need for periodic full risk assessments** (incremental updates — exam answer).
- Expect post-incident scenarios: update controls based on **root cause analysis**.

Awareness & Training (3B4)

- Most incidents involve **human error** — training embeds security into culture. Continuous from onboarding; includes third parties with access.
- **Tailor by role:** execs (risk appetite, tone at the top), privileged users (heightened responsibility), physical security staff, end users (phishing, passwords, reporting). Some roles need more frequent training (HIPAA, PCI DSS).
- Methods: CBT, phishing simulations, newsletters, posters, login banners, visible enforcement, security duties in job descriptions/reviews.
- Metrics: coverage (completion %), competence (test scores), LMS tracking. Long-term success = better behavior: fewer user-error incidents, lower phishing clicks, faster reporting.
- **Best indicator training worked: MORE incidents reported** (people notice and speak up). “No incidents reported” proves nothing (exam trap).

Management of External Services (3B5)

- **You can outsource the task, NEVER the accountability** for security.
- **Before:** risk assessment, due diligence, risk clauses in contract. **During:** manage risk, reassess on significant change. **After:** offboarding — data return/destruction, access removal. **Plan the exit strategy from the start.**
- **FIRST step before granting an external party access: a risk assessment** (exam answer — due diligence and contract review are parts of it).
- Transparency problem → strong **SLAs:** required protection levels (SOC 2, ISO 27001), **right-to-audit clauses**, incident response protocols, BC/DR requirements. Ask for the vendor’s last external audit/pentest.
- **Contract provisions:** confidentiality/NDA, defined security controls, network connectivity security, right to audit, incident notification timelines, indemnity (watch liability caps), choice of law, data ownership, least-privilege access, offboarding specifics.

Communication, Reporting & PDCA (3B6)

- Report to leaders on objectives, risk status, improvements — leaders unaware of risks face **legal/financial liability**.
- **PDCA:** PLAN (design program/strategy/policies) → DO (execute, integrate into routine practice) → CHECK (monitor, audit, review with metrics) → ACT (corrective/preventive/improvement actions). Aligns with TQM; continuous loop.
- Program evaluation = security health check (strategy, policies, compliance, operations, technical mgmt, resources); **escalate gaps to senior management**.
- Reviews: control self-assessments, architecture reviews, spot checks. Audits = formal, independent; build a positive auditor relationship.
- Compliance: risk-based **formal exception process**; track and resolve noncompliance promptly.
- **Clearly defined roles & responsibilities → accountability** (exam answer — the most important benefit).

Quick Self-Check (from the handout)

1. Select security tech primarily based on? → **Ability to mitigate business risks**
2. Best way to ensure platform settings comply with policy? → **Establish security baselines**

3. Why include threat/vuln assessment in change management? → **Reduces need for periodic full risk assessments**
4. Best indicator awareness training is effective? → **More incidents reported**
5. FIRST step before external party gets data center access? → **Risk assessment**
6. Most important benefit of clear roles & responsibilities? → **Accountability**

Last-Minute Memory Hooks

- Business risk mitigation beats every other selection criterion
- Safety fails OPEN; security fails CLOSED; default is DENY
- Signature = sender's private key; encryption = recipient's public key
- Outsource the work, keep the accountability
- Risk assessment comes FIRST — before contracts, access, or due diligence
- More reporting = better awareness; silence ≠ security
- Every control change → change management + acceptance testing
- "Most important resource" answers: people and management support, not technology